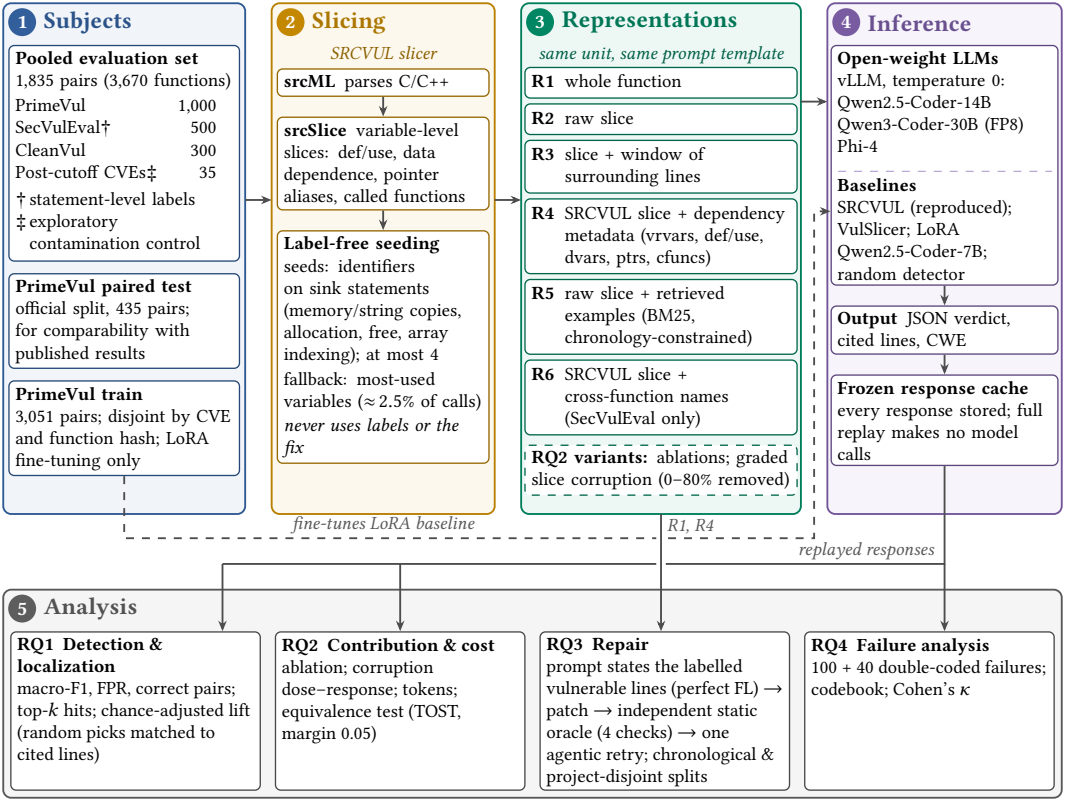

1 Subjects
Pooled evaluation set
1,835 pairs (3,670 functions)
PrimeVul 1,000
SecVulEval† 500
CleanVul 300
Post-cutoff CVEs‡ 35
† statement-level labels
‡ exploratory contamination control
PrimeVul paired test
official split, 435 pairs; for comparability with published results
PrimeVul train
3,051 pairs; disjoint by CVE and function hash; LoRA fine-tuning only
2 Slicing
SRCVUL slicer
srcML parses C/C++
srcSlice variable-level slices: def/use, data dependence, pointer aliases, called functions
Label-free seeding
seeds: identifiers on sink statements (memory/string copies, allocation, free, array indexing); at most 4
fallback: most-used variables (≈ 2.5% of calls)
never uses labels or the fix
3 Representations
same unit, same prompt template
R1 whole function
R2 raw slice
R3 slice + window of surrounding lines
R4 SRCVUL slice + dependency metadata (vrvars, def/use, dvars, ptrs, cfuncs)
R5 raw slice + retrieved examples (BM25, chronology-constrained)
R6 SRCVUL slice + cross-function names (SecVulEval only)
RQ2 variants: ablations; graded slice corruption (0–80% removed)
4 Inference
Open-weight LLMs
vLLM, temperature 0:
Qwen2.5-Coder-14B
Qwen3-Coder-30B (FP8)
Phi-4
Baselines
SRCVUL (reproduced); VulSlicer; LoRA Qwen2.5-Coder-7B; random detector
Output JSON verdict, cited lines, CWE
Frozen response cache
every response stored; full replay makes no model calls
fine-tunes LoRA baseline
R1, R4
replayed responses
5 Analysis
RQ1 Detection & localization
macro-F1, FPR, correct pairs; top-k hits; chance-adjusted lift (random picks matched to cited lines)
RQ2 Contribution & cost
ablation; corruption dose–response; tokens; equivalence test (TOST, margin 0.05)
RQ3 Repair
prompt states the labelled vulnerable lines (perfect FL) → patch → independent static oracle (4 checks) → one agentic retry; chronological & project-disjoint splits
RQ4 Failure analysis
100 + 40 double-coded failures; codebook; Cohen's κ